

Security & Vulnerability Response Policy

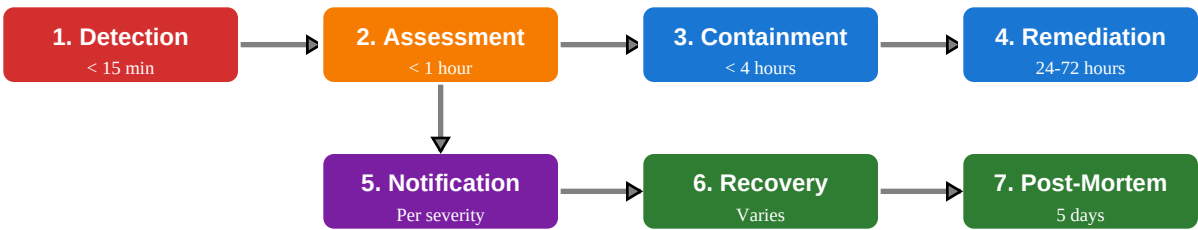
Enterprise Resolution Intelligence System

Effective Date:	January 1, 2026	Version:	2.1
Owner:	Chief Information Security Officer	Review Cycle:	Quarterly

1. Incident Severity Classification

Severity	Definition	Examples	Response Time
Critical (P0)	Active exploitation, data breach, widespread impact	- Active data exfiltration - RCE vulnerability - Auth bypass in production	< 15 min
High (P1)	High likelihood of exploitation, significant risk	- SQL injection discovered - Privilege escalation - PII exposure	< 1 hour
Medium (P2)	Moderate risk, requires mitigation	- XSS vulnerabilities - Missing rate limits - Weak encryption	< 24 hours
Low (P3)	Minimal risk, hardening opportunity	- Info disclosure - Non-sensitive config - Security headers	< 7 days

1.1 Incident Response Timeline



Response Timeline:

■ Detection ■ Assessment ■ Response ■ Resolution

2. Security Patch & Update Timelines

Severity	Patch Development	Testing	Deployment	Total SLA
----------	-------------------	---------	------------	-----------

Critical	< 4 hours	< 2 hours	< 2 hours	< 8 hours
High	< 24 hours	< 8 hours	< 4 hours	< 36 hours
Medium	< 5 days	< 2 days	< 1 day	< 7 days
Low	< 21 days	< 5 days	< 4 days	< 30 days

Patch Deployment Process:

- **Emergency patches:** Deployed during business hours with minimal notice
 - **Scheduled patches:** Deployed during maintenance windows (Sundays 2-6 AM UTC)
 - **Communication:** 24-hour advance notice for High/Medium patches via status page
 - **Rollback plan:** Automated rollback within 30 minutes if issues detected
-

3. Responsible Disclosure Program

3.1 Reporting Security Vulnerabilities

We welcome responsible disclosure of security vulnerabilities:

- **Email:** security@example.com (PGP key available)
- **Bug Bounty:** <https://bugcrowd.com/example> (rewards: \$100-\$10,000)
- **Response time:** Initial acknowledgment within 24 hours
- **Updates:** Progress updates every 5 business days

3.2 Disclosure Guidelines

✓ Encouraged	✗ Prohibited
• Proof-of-concept code • Detailed reproduction steps • Impact assessment • Suggested mitigations	• Public disclosure before fix • Testing on production data • Social engineering attacks • DoS/DDoS attacks

3.3 Coordinated Disclosure Timeline

- **Day 0:** Vulnerability reported
 - **Day 1:** Acknowledgment and triage
 - **Day 1-30:** Investigation, patch development, testing
 - **Day 30-45:** Patch deployment to production
 - **Day 45-90:** Public disclosure with researcher credit (if agreed)
-

4. Data Breach Response Protocol

Phase	Actions	Timeline	Responsible Party
Detection	• Identify breach scope • Preserve evidence • Document timeline	Immediate	Security Team
Containment	• Isolate affected systems • Revoke compromised credentials • Block attack vectors	< 1 hour	Security + DevOps
Assessment	• Determine data exposure • Identify affected users • Assess legal obligations	< 4 hours	Security + Legal
Notification	• Notify regulators (GDPR: 72hrs) • Inform affected users • Public disclosure if required	Per regulation	Legal + Comms
Remediation	• Apply security fixes • Reset credentials • Enhanced monitoring	< 7 days	Security + Engineering

Regulatory Notification Requirements:

- **GDPR:** 72 hours to supervisory authority, without undue delay to data subjects
 - **CCPA:** Without unreasonable delay to California residents
 - **State laws:** Varies by jurisdiction (typically 30-90 days)
 - **Credit monitoring:** Offer 12-24 months for SSN/financial data breaches
-

5. Escalation Hierarchy & Communication



Role	Responsibilities	Contact
Security Team	24/7 monitoring, initial response, triage	security@example.com +1-800-SEC-OPS
Security Lead	Incident coordination, vendor management	security-lead@example.com PagerDuty escalation
CISO	Executive decisions, regulatory liaison	ciso@example.com Direct: +1-555-CISO
Legal Counsel	Regulatory compliance, disclosure guidance	legal@example.com
PR/Communications	External communications, media response	pr@example.com

6. Post-Incident Review Requirements

Within 5 business days of incident closure, conduct post-mortem including:

- **Timeline reconstruction:** Complete incident timeline with all actions taken
- **Root cause analysis:** Technical and procedural factors that enabled incident
- **Impact assessment:** Systems affected, data exposed, downtime incurred
- **Response effectiveness:** What worked well, what needs improvement
- **Action items:** Preventive measures with owners and deadlines
- **Documentation:** Store in secure incident database for trend analysis

Security Contact Information

Security Operations: security@example.com | Emergency Hotline: +1-800-SEC-OPS

Bug Bounty: <https://bugcrowd.com/example> | Security Advisories: <https://security.example.com>

PGP Key: <https://example.com/pgp-key.asc>